DOC-07｜部署、監控、備份與災難復原計畫

水電工程管理系統 | 維運交付規格 v1.0 | 2026-11-10

文件狀態：設計提案／待環境驗證。依據 DOC-01～DOC-06 及已核准政策。未建立任何部署、備份或監控設定；RPO 1 小時與 RTO 4 小時為目標而非已達成的承諾。

01 | 目的、範圍與責任

確保工程、客戶、維修、材料、採購、零用金、報價與收付款資料，在版本發布、服務中斷、誤刪及災害情境下可安全維護與復原。維運涵蓋應用程式、PostgreSQL、物件儲存、身分驗證、排程工作、金鑰與審計證據。

責任角色	主要職責
Owner／系統負責人	核准正式發布、資料還原、緊急停機與對外通報
工程維護者	建置、監控、修復、備驗證、事故處理與文件維護
資料管理者（授權）	核對資料完整性、財務與庫存對帳、協助復原驗收
一般員工	回報異常，不得存取正式環境密或備

02 | 環境與發布治理

環境	用途	資料及存取
DEV	功能開發及單元測試	使用虛構或去識別資料；不得共用 PROD 金
STAGING	整合、E2E、UAT、還原演練	與正式環境隔離；可使用匿名化樣本
PROD	正式營運	最小權限、制稽核、發布審核與監控

技術架構暫以 Next.js／Vercel、Supabase PostgreSQL／Auth／Storage 為候選，尚待技術選型批准。不得將特定供應商功能視為已啟用或保證可用。

標準發布流程

1. PR 審查、型別檢查、lint、單元與整合測試通過。2. 生成版本號、變更清單及資料庫 Migration 審查。3. 部署 STAGING 並執行八條核心 E2E 與安全測試。4. 驗證備份／還原可用及回滾路徑。5. Owner 核准正式發布時段。6. PROD 漸進發布並監控。7. 發布後核對登入、庫存、採購、請款、照片及背景工作。

03 | 備份政策：RPO／RTO

指標	已核准目標	驗證方式
RPO	≤1 小時	以故障時間與最後可還原且一致的資料點比較
RTO	≤4 小時	從宣告災難至核心服務及資料核對恢復可用
資料範圍	DB、照片、PDF、必要設定與密恢復程序	抽樣還原與附件一致性比對
演練頻率	建議每季一次，重大變更後追加	保留時間、步驟、耗時、結果與簽核

備份頻率與保留天數需依實際方案與費用決定。只有每日完整備份通常無法單獨保證 1 小時 RPO；可能需要 PITR／WAL 或等效連續備份。DB PITR 不會自動保證 Storage 物件同步還原，須另設物件版本化、異地複本或可驗證的增量備份。

備份安全要求

備份應加密、限制存取、隔離正式服務帳號並保留操作稽核；備份金鑰及恢復憑證不可與唯一一份備份放在同一故障域。刪除與保留期限應遵守資料保護需求。建議定期抽驗備份可讀性及完整性，而非只檢查工作是否顯示成功。

04 | 災難分類與復原順序

等級	範例	初步處置
SEV-1	跨組織資料外洩、財務錯帳、不可用且影響所有人	停止危險寫入、保全證據、立即通知 Owner
SEV-2	主要功能中斷、照片大量無法存取	暫停相關流程、切換降級模式、動修復
SEV-3	局部頁面異常、少量重試失敗	建立事件單、評估修復及下一版本

建議復原優先順序：①身分與組織隔離 ②核心資料庫一致性 ③庫存與採購交易 ④收款與帳款 ⑤工程／維修資料 ⑥照片與 PDF ⑦ 統計與非核心功能。若財務或庫存一致性無法證明，相關寫入功能應維持唯讀或暫停。

復原演練操作契約

A. 宣告事件與紀錄 T0；B. 凍結危險寫入、保留故障證據；C. 選定一致的資料庫復原點；D. 在隔離環境還原 DB、物件及必要設定；E. 驗證組織隔離、資料筆數、庫存帳、應收應付、照片連結；F. 切換服務與 DNS／流量；G. 恢復寫入前完成 Owner 確認；H. 記錄最後可用交易時間及 T_restore，計算實測 RPO／RTO。

05 | 資料庫 Migration 與回滾

Migration 以版本化、可重複驗證與向後相容為原則。先新增欄位或表，再發布支援新舊結構的程式，完成資料回填及驗證後，才於後續版本移除舊結構。禁止未備份就直接執行不可逆刪除或欄位重命名。

變更類型	回滾策略
純應用程式更新	重新指向上一個經驗證版本；驗證資料相容
可逆結構變更	執行經測試的逆向 Migration 或前向修復
不可逆資料變更	先建立還原點與資料快照；採受控前向修復或完整還原
金流／庫存已生新交易	禁止直接回復舊 DB 導致交易遺失；須評估對帳與補償方案

06 | 監控、告警與稽核

監控類別	觀測項目	告警／處置方向
可用性	□□□□□□□□□□ API、錯誤率	持續失敗通知維護者
效能	API 延遲、資料庫連線、慢查詢	達警戒值分析瓶頸
資料一致性	負庫存、超額採購、重複收款、未配平帳款	任何異常高優先級阻
同步／排程	□□□□□□□□□□□□□□□□□□	重試與人工介入
備份	備新鮮度、完整性、還原測試結果	超過 RPO 可用窗口立即告警
安全	跨組織拒絕、異常登入、敏感匯出	調查並保全稽核證據

日誌需有 request_id、organization_id（必要時遮罩）、操作類型、結果與時間；不得寫入密碼、Access Token、門禁碼、完整信用資訊或未必要的個資。告警通道與值班人員由正式維運安排決定。

07 | 資料安全、憑證與權限撤銷

正式密鑰放在受控環境變數或秘密管理服務；前端不得取得 Service Role。定期輪替憑證並演練洩漏撤銷；離職或停用成員應立即失去敏感 API 與檔案存取。簽名網址短效、匯出受權限管控。事故證據應限制閱覽並保留處置紀錄。

08 | 發布前驗收清單

編號	必須通過的驗收	未通過時
OPS-01	備方案具備 1 小時內可恢復的資料點	阻發布
OPS-02	實際演練 RTO ≤ 4 小時	阻發布
OPS-03	資料庫與照片／PDF 均可還原比對	阻發布
OPS-04	恢復後庫存、採購、財務帳一致	阻發布
OPS-05	STAGING 八條 E2E 全通過、P0/P1 零未解缺陷	阻發布
OPS-06	回滾／停寫／通知程序經演練	阻發布
OPS-07	權限、RLS、密、備存取稽核通過	阻發布
OPS-08	Owner 已核准發布與事故責任窗口	阻發布

09 | 事故紀錄與事後檢討

每次事故需記錄：事件編號、起訖時間、影響模組、資料完整性風險、初步原因、已執行操作、證據、實測 RPO／RTO、補救與預防措施、Owner 簽核。若涉及客戶個資或法規通報，依適用法律及契約另行處理，不在本文件推定法定時限。

10 | 待確認事項與交付聲明

項目	目前狀態
正式技術選型／付費方案	待核准；需驗證 PITR、物件備份及保留功能
備份保留期間與異地策略	待確認成本、法遵及資料量
正式網域、值班與告警通道	待設定
密鑰輪替週期與演練負責人	待指定
資料留存／刪除政策	待依業務及法規確認

本文件為 DOC-07 設計規格，不代表備份已啟用、RPO／RTO 已達標或任何環境已部署。七份 DOC-01～DOC-07 文件完成後，應進行交叉一致性審查、待決政策清冊與版本封版；未經使用者明確授權，不建立程式、資料庫、GitHub Issues 或部署。